
Cyberboswachters

De beste digitale stropers zijn ook de beste cyberboswachters

Dams Tim



IoT Security

Introductie

We spraken in het eerste hoofdstuk al over de problemen die inherent zijn bij Internet-of-Things (IoT) apparaten en netwerken. Zo had je in 2016 het Mirai-botnet dat aantoonde hoe krachtig een botnet van IoT-apparaten kan zijn, puur door de grote hoeveelheid potentiële zombies.

Het is niet toevallig dat we dit boek afsluiten met het hoofdstuk omtrent IoT Security: alles (en meer) wat je in de voorgaande hoofdstukken hebt geleerd heb je namelijk nodig om IoT-netwerken te beveiligen. Er zijn zoveel potentiële manieren voor digitale stropers om misbruik te maken van een slecht beveiligd IoT apparaat of netwerk dat het complexe probleem van netwerken beveiligen nog ingewikkelder is geworden door de eigenschappen van IoT apparaten, namelijk:

- Van nature zijn ze **low-power**, daar ze vele dagen of weken moeten voortkunnen zonder te veel verbruik. Ingebouwde security protocols mogen dus geen grote percentages van het vermogen opsouperen, zeker niet als dat ten koste is van de hoofdbestaansredenen van het apparaat.
- Meestal, ook weer om een laag energieverbruik te behouden, hebben ze ook een **beperkte bandbreedte** ter beschikking (daarbij: beeld je de miserie op een wifi-netwerk in wanneer honderden kleine sensoren aan hoge bandbreedtes het netwerk mee gebruiken).
- Zowel de fysieke dimensies, en bovenstaande 2 eigenschappen, zorgen er ook voor dat IoT-apparaten meestal maar een beperkt aantal zaken *kan*. Het heeft niet altijd de netwerkverbindingsmogelijkheden die je nodig hebt (meestal heeft een apparaat of bluetooth, of wifi, of een bedrade aansluiting, maar zelden alle drie) en ook qua opslag en processormogelijkheden zijn de apparaten uiteraard vaak veel beperkter dan de kracht van computers en mobiele telefoons. Het grootste probleem echter hiervan is dat IoT-apparaten *by nature* vaak **niet evident zijn om te updaten**. Sommige apparaten kunnen bijvoorbeeld enkel geüpdate worden door fysiek aan het apparaat te zijn (en dan door de firmware te flashen bijvoorbeeld). Vanuit een fysieke beveiligingsconcept is dat goed, maar niet als je apparaten een kritieke beveiligingslek hebben die dringend gepatch'd moet worden.



We gaan nogal liberaal om met de term IoT-apparaat, waarbij we ook negeren dat er grote verschillen zijn tussen “Enterprise IoT” en “huis-tuin-en-keuken IoT”. Die eerste heeft meestal bijvoorbeeld wel zeer doordachte updatestrategieën en dergelijke, terwijl de slimme koelkast in je huis dat vermoedelijk niet zal hebben

OWASP IoT Top 10

Het Open Web Application Security Project (OWASP) is een open source-project rond computerbeveiliging. Individuen, scholen en bedrijven delen via dit platform informatie en technieken. (bron Wikipedia). Ook de Belgische tak van OWASP is erg actief en een interessante organisatie indien je van plan bent om een carrière binnen de cybersecurity wereld op te bouwen. Ze organiseren geregeld (meestal gratis) workshops en evenementen.

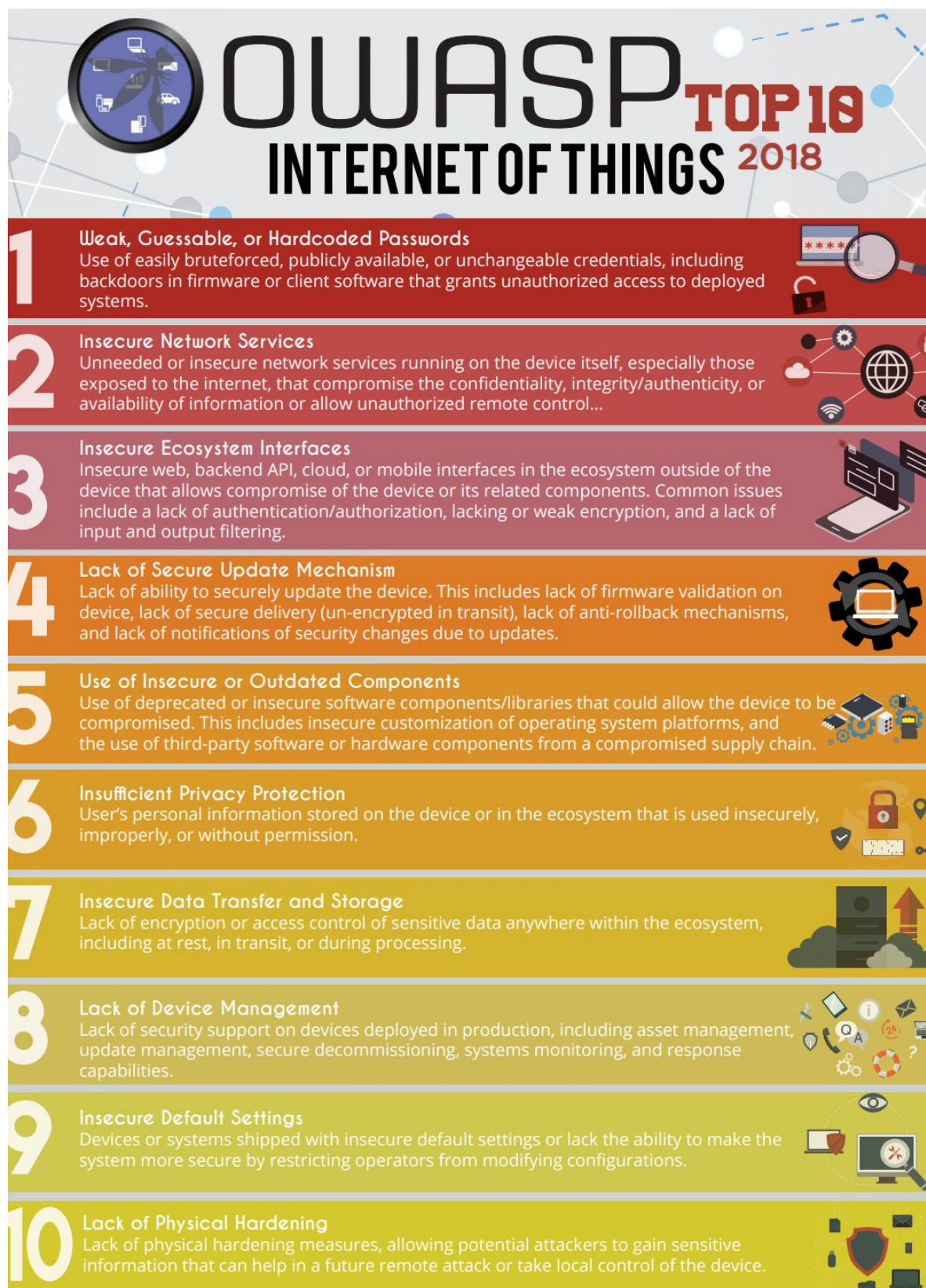
Het OWASP heeft tal van erg interessante “Top 10” overzichten zoals de meest voorkomende webapp zwakheden, etc. Deze projecten bestaan meestal uit een hele reeks tools, *best practices* en gidsen en zijn dus de ideale manier om je te verdiepen binnen een specifiek cybersecurity domein. Eén van de actieve projecten is het “OWASP Internet of Things” project (beschikbaar via owasp.org/www-project-internet-of-things/) waarvan we de Top 10 hier zullen bespreken, gerangschikt van meest voorkomend (en dus belangrijkste om aan te pakken) naar minder.



Bekijk zeker ook eens het IoT Goat project via github.com/OWASP/IoTGoat/ dat is een *“insecure firmware based on OpenWrt and maintained by OWASP as a platform to educate software developers and security professionals with testing commonly found vulnerabilities in IoT devices. The vulnerability challenges are based on the OWASP IoT Top 10, as well as “easter eggs” from project contributors.”*



Om de wel erg algemene term “IoT” wat duidelijker te maken zullen er hier en daar merknamen en producten worden vermeld. Dit is hoegenaamd geen verdoken reclame (of kritiek) voor deze producten, maar gewoon een poging om de lezer een duidelijkere context te geven.



Figuur 0.1: Versie 2018, bron owasp.org)

Paswoorden

Ook bij IoT begint veiligheid uiteraard bij het hebben van goede, complexe, moeilijk te raden wachtwoorden. Bij IoT-apparaten komt echter een stevige drempel, zeker voor huis-tuin-en-keuken gebruikers: het aanpassen van sommige IoT-apparaten is soms erg omslachtig. Niet alle apparaten hebben een webpagina langs waar de gebruiker paswoorden kan aanpassen en moet dit via ofwel omslachtige, vreemde tools, oftewel (gruwel) door fysiek het apparaat te bedienen. Deze apparaten zijn natuurlijk niet gemaakt om complexe paswoorden eenvoudig in te voeren. Denk maar aan een digitale weegschaal: die heeft vaak een eenvoudig LED-scherm waarop je gewicht wordt getoond. Sommige weegschalen kan je vervolgens “bedienen” door links of rechts op de schaal te klikken, afhankelijk van wat je wilt doen. De auteur kan je garanderen: je paswoord zal niet lang zijn, als je een goed paswoord wilt invoeren zal je na enkele minuten in het zweet staan van de tapdans die je moet uitvoeren op je weegschaal.

Omdat het aanpassen van die paswoorden dus vaak zo omslachtig is, zullen gebruiker meestal opteren om het *default password* te gebruiken. Ze redeneren dat **dit simpele IoT apparaat zal niemand toch willen hacken**. “Wat kan een hacker nu doen met toegang tot mijn digitale thermometer.” Wat echter vergeten wordt is dat cyberstropers altijd op zoek gaan naar de *weakest link*, om die vervolgens te misbruiken om tot het eigenlijk doel te geraken. Kortom, ieder IoT-apparaat in je omgeving is een potentiële toegangspoort tot de rest van je netwerk!

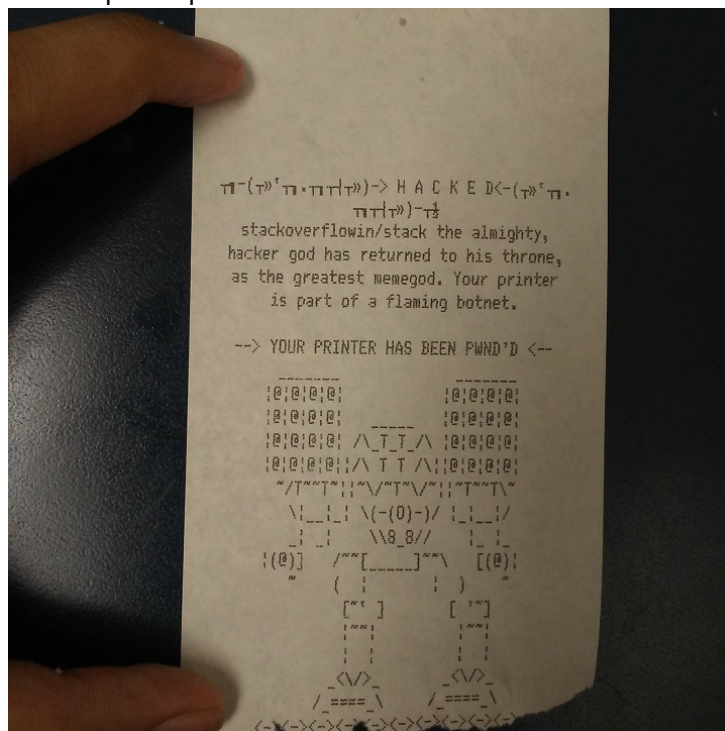
Ongebruikte of onveilige netwerkservices

Als je anno 2021 een printer koopt dan zal dit apparaat bijna altijd een IoT-apparaat zijn dat je toelaat om vanop afstand te printen. Echter, dergelijke apparaten hebben vaak tal van netwerkservices draaien waarvan de gewone huis-tuin-en-keuken gebruiker weinig of niets van afweet. Vergelijk dit bijvoorbeeld met Microsoft Windows: heb je al eens gekeken welke services allemaal permanent op je systeem draaien (Start -> uitvoeren -> `services.msc`) ? Dit soort diensten uitzetten behelst ook weer dat de gebruiker weet heeft van een webpagina met administrator-instellingen. Soms zijn die diensten op de koop toe essentieel voor de goede werking van het apparaat en ze uitzetten is dan geen optie. Maar wat als die service op zich inherent onveilig is ?! Zo zijn er apparaten die enkel *telnet*-sessies gebruiken om het apparaat in te stellen. Een telnet-sessie geeft je een remote shell die echter **onversleuteld** met het apparaat communiceert (in tegenstelling tot bijvoorbeeld SSH, Secure Shell, dat wél veilige communicatie aanbiedt).

Kortom, het is aangeraden om altijd te controleren welke services nu eigenlijk actief zijn op je apparaat.

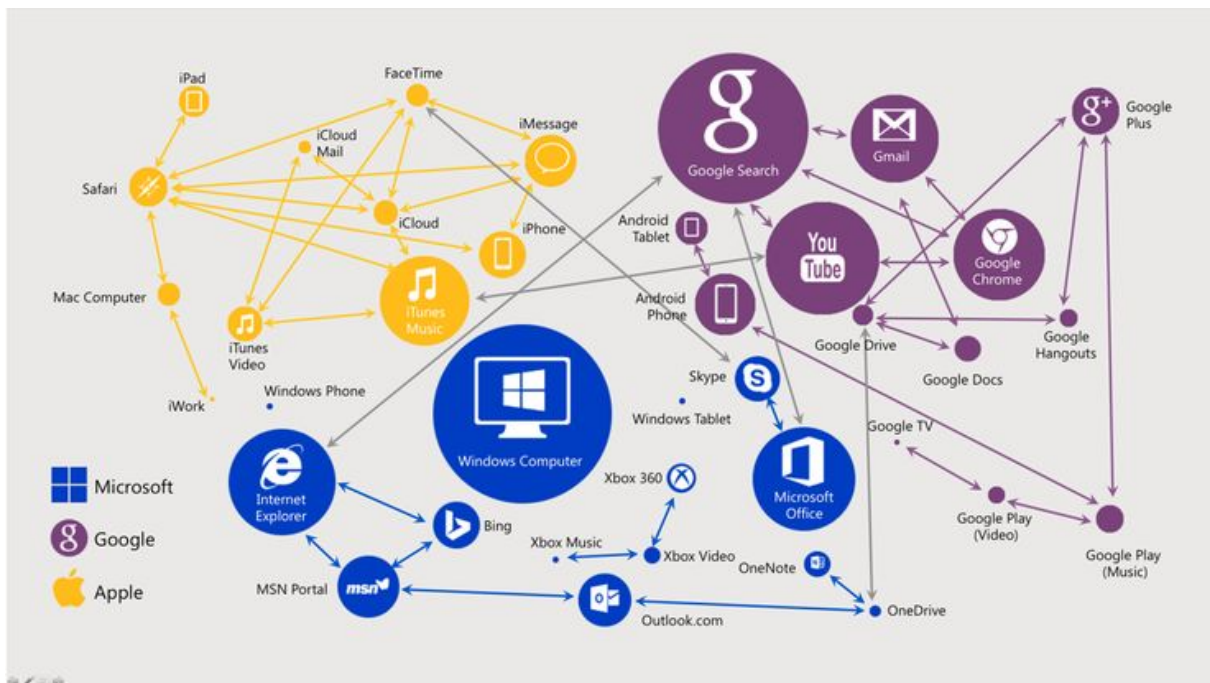


In 2017 was er een grayhat hacker die vermoedelijk 150.000 printers vanop afstand in Nederland kon benaderen. Vervolgens printte hij “ludieke” berichten op de printers om de gebruikers er op te wijzen dat ze een onveilig apparaat gebruiken. In dit geval gebruikte hij poort 9100 van de printer die in veel merken wordt gebruikt om vanop afstand print-opdrachten door te sturen.



Onveilig ecosysteem

Een IoT-apparaat bestaat niet alleen: meestal maakt het deel uit van een verzameling apparaten en diensten die de gebruiker via online dashboards en apps kan bedienen. Denk maar aan de verschillende Google Nest producten (thermostaat, deurbel, maar ook de Hub, etc.) of lichten van Philips (Hue) die ook met behulp van andere toestellen kunnen bediend worden (bijvoorbeeld drukknoppen van Niko of Ikea). Kortom, IoT-apparaten maken meestal deel uit van een heus ecosysteem en dus de mate van veiligheid van die externe zaken bepaald ook die van het IoT-apparaat. Als bijvoorbeeld de dashboards van fitbit.com zouden gecompromitteerd worden bestaat de kans dat de digitale stropers ook toegang tot je gegevens of apparaten krijgen die gebruik maken van het fitbit-portaal.



Figuur 0.2: Een voorbeeld van de complexiteit van ecosystemen. In dit geval een vereenvoudigde voorstelling van die van Apple, Google en Microsoft. Bron van deze afbeelding is helaas onbekend

Gebruikers vergeten ook vaak met welke externe diensten ze hun apparaten hebben gekoppeld. Het gebeurt vaak dat een gebruiker “even iets wil testen” (denk maar de nuttige website “[If this then that](#)” dat toelaat om services en apparaten te koppelen die iets moeten doen gegeven zelfgekozen triggers en regels) maar nadien wel vergeet deze koppeling uit te zetten. Dit geldt ook voor de vele third-party websites en services die bijvoorbeeld toegang tot uw google of facebook-accounts wensen. Veel gebruikers kijken dit nooit na en hebben mogelijk tien jaar geleden al toegang gegeven aan een service die ondertussen al geregeld door digitale stropers is gecompromiteerd.



Je moet maar eens google’n naar bijvoorbeeld “google ecosystem” of eender welk ander grote silicon valley bedrijf. Je zal versteld staan van de complexiteit en grootte ervan.

Geen of onveilig updatemechanisme

Dit werd al in de introductie van dit hoofdstuk aangehaald. Het updaten van fysieke apparaten is niet evident, zeker niet als het gaat om kleine, low-power-apparaten die mogelijk op de koop toe ook nog eens op een moeilijk bereikbare plaats hangen en dus enkel praktisch geüpdate kunnen worden als ze een remote update-mechanisme ondersteunen.

Daarnaast kan het ook gebeuren dat een update, om welke reden dan ook, mislukt waardoor het systeem potentiëel *gebrickt* geraakt en de gebruiker of administrator dan alsnog een fysieke rollback moet doen (als het apparaat die mogelijkheid heeft natuurlijk). Er zijn ondertussen erg dikke boeken geschreven over de *wondere wereld van het updaten van IoT apparaten*. Weet dus dat het erg belangrijk is dat je als cyberboswachter van IoT-netwerken erg goed weet wat de update-strategieën van je IoT-apparaten zijn en wat je moet doen als er hier problemen optreden. Merk op dat die problemen zowel als gevolg van digitale stropers kunnen, maar ook door slechte updates van de fabrikant die op hun beurt mogelijk nieuwe beveiligingsproblemen in je apparaten introduceren.



Vaak zijn we afhankelijk van de fabrikanten om beveiligingslekken te dichten in onze software en hardware. Uiteraard zijn er fabrikanten die maar *x* aantal jaren patches uitbrengen, en er zijn ook al tal van IoT-apparaten op de markt waarvan de fabrikant al jaren niet meer bestaat.

Of wat te denken als er een kritieke bug wordt gevonden in een chip die ontelbare apparaten gebruiken. Wie moet dan de patch voorzien: de fabrikant van het IoT-apparaat, of die van de chip?

In september 2021 verscheen een nieuwe Bluetooth kwetsbaarheid, getiteld **BrakTooth** die mogelijk op miljarden IoT-apparaten kan misbruikt worden. De bug zelf bevindt zich in de Bluetooth-chip van de apparaten. Aardig wat fabrikanten van dergelijke chips hebben al beloofd een patch uit te brengen, maar er zijn er ook die simpelweg zeggen “we zullen enkel patchen als er genoeg vraag naar is”, nochtans kan de kwetsbaarheid eg veel schade aanbrengen (DoS-aanvallen en *arbitrary code execution (ACE)*)

[Meer informatie](#)

Oude of onveilige componenten

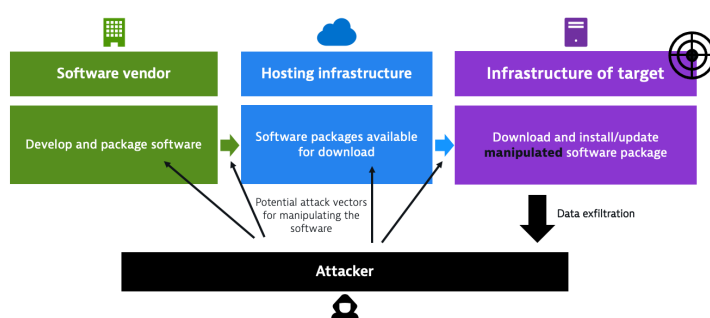
Het voorgaande voorbeeld i.v.m. BrakTooth kan ook in deze sectie gebruikt worden. Een IoT-apparaat is en blijft een combinatie van tientallen, soms honderden hardware-onderdelen. De kans dat al deze onderdelen van de IoT-fabrikant zijn is onbestaande. Gooi eender welke smartphone of digitale horloge open en je zal tal van onderdelen vinden van een andere fabrikant. De IoT-fabrikant moet er dus vanuit gaan dat deze componenten voldoen aan de veiligheidseisen die hij van z’n eigen product verwacht. Dat is geen evidentie.

Een zelfde fenomeen zien we enkele lagen hoger in de OSI-stack: ook op software niveau gebeurt het zelden dat de IoT-ontwikkelaars alle bibliotheken en protocols *van scratch* hebben ontwikkeld (en dus ook zelf kunnen instaan voor de robuustheid ervan inzake cyberveiligheid). Wanneer er een bug (of bewuste backdoor) wordt ontdekt in een protocol of bibliotheek, dan heeft dit gevolgen voor alles en iedereen die deze dingen in zijn of haar apparaten gebruikt.



In 2020 was er veel heisa omtrent de zogenaamde *SolarWinds-hack*. Duizenden grote bedrijven (en Amerikaanse overheidinstelling) zoals Microsoft gebruiken het Orion Platform van dit bedrijf. Dit platform laat toe om enterprise netwerken te monitoren en managen, iets wat niet evident is op de schaal waarmee de klanten van SolarWinds werken. Deze tool moet natuurlijk waterdicht zijn, wat deze niet bleek te zijn: hackers sloegen er in om de FTP-esrver van SolarWinds te benaderen (het paswoord was *solarwinds123...*) en konden zo een backdoor in het Orion platform inbouwen. Vervolgens, wanneer de klanten van SolarWinds, hun Orion-installatie update'n, kregen ze onvrijwillig een versie met een bewust ingebouwde backdoor die de hackers vervolgens konden misbruiken.

Dit soort aanval heet een **supply chain attack**: de aanvallers richten zich op de weakest link binnen de supply chain om zo finaal tot bij de klant *achteraan* de keten te geraken.



Onvoldoende privacy bescherming

Onveilige datatransfer en opslag

Gebrek aan apparaat management

Onveilige standaard instellingen

Gebrek aan fysieke *hardening*

Bronnen

- 802.11 Wireless Network (first edition), Gast, O'Reilly, ISBN: 0-596-0018-3
- Meerdere boeken van William Stallings (Computer Security, Cybersecurity, etc.)

